[기관 로고]

기밀 / CONFIDENTIAL

웹 취약점 진단

웹 취약점 진단 결과 보고서

대상 기관	*Example Customer*
수행 기관	*Example Security*
작 성 일	*2026-03-19*
문서 버전	*v1.0*
문서 등급	*internal*

본 문서는 편집용 템플릿입니다. 모든 [대괄호] 항목을 실제 내용으로 교체하여 사용하십시오.

목 차

1. 개요 4
1) 목적 4
2) 문서 통제 및 진단 조건 4
3) 수행 범위 4
4) 대상 5
5) 일정 5
6) 수행 인력 5
7) 수행 장소 5

2. 웹 취약점 진단 개요 6
1) 점검 기준 6
2) 진단 절차 6
3) 활용 도구 6
4) 위험도 기준 7
5) 점검 체크리스트 7

3. 웹 취약점 진단 결과 요약 8
1) 전체 취약점 요약 8
2) 위험도별 현황 8
3) 대상별 결과 요약 9
4) 총평 9
5) 조치 우선순위 9

4. 웹 취약점 진단 상세 결과 10
1) VUL-001 · 로그인 실패 횟수 제한 미흡 10

5. 보호대책 12
1) 단기 조치 12
2) 중기 조치 12
3) 장기 조치 12

[부록] 상세 점검 체크리스트 13
[부록] 점검 기준 참고표 14
[부록] 추가 증빙 자료 15

표 차례

[표 1] 문서 이력 4
[표 2] 검토 및 승인 4
[표 3] 진단 전제 및 제한 사항 4
[표 4] 수행 범위 4
[표 5] 웹 취약점 진단 대상 5
[표 6] 절차 및 일정 5
[표 7] 수행 인력 5
[표 8] 수행 장소 및 IP 주소 5
[표 9] 웹 취약점 진단 방법 6
[표 10] 활용 도구 6
[표 11] 위험도 기준 7
[표 12] 웹 취약점 진단 체크리스트 7
[표 13] 전체 취약점 요약 8
[표 14] 위험도별 취약점 현황 8
[표 15] 대상별 결과 요약 9
[표 16] 조치 우선순위 9
[표 17] 단기 조치 목록 12
[표 18] 중기 조치 목록 12
[표 19] 장기 조치 목록 12
[표 20] 점검 기준 참고표 14
[표 21] 취약점 코드 참고표 14

그림 차례

[그림 1] 웹 취약점 진단 절차 흐름도 6
[그림 4] VUL-001 재현 증빙 화면 10
[그림 5] VUL-001 재현 증빙 화면 10
[그림 02] Appendix C 추가 증빙 화면 (#1) 15
[그림 03] Appendix C 추가 증빙 화면 (#2) 15
[그림 04] Appendix C 추가 증빙 화면 (#3) 10
[그림 05] Appendix C 추가 증빙 화면 (#4) 10

1. 개요

1) 목적

본 웹 취약점 진단은 Example Customer의 phase-1 web sample 서비스에 대한 보안 위험을 식별하기 위해 수행되었습니다.

> *고객사와 합의된 Web 범위만 수동 검증 대상으로 포함합니다.*

2) 문서 통제 및 진단 조건

문서 이력, 검토 체계 및 진단 수행 전제조건은 아래와 같이 관리합니다.

버전	작성일	작성/수정자	변경 내용
v1.0	2026-03-19	홍길동	초안 작성

[표 1] 문서 이력

구분	소속/부서	성명	상태	비고
작성		홍길동	작성 완료	Analyst

[표 2] 검토 및 승인

구분	내용	적용 여부
진단 전제 조건	*staging 환경과 비인가 상태를 기준으로 점검을 수행했습니다.*	*적용*
제외 범위	*운영 시스템 및 Web 외 범위는 제외했습니다.*	*적용*
제한 사항	*외부 SaaS/API 호출 없이 로컬 파일 기반 증빙만 사용했습니다.*	*적용*

[표 3] 진단 전제 및 제한 사항

3) 수행 범위

본 진단은 아래 범위를 기준으로 수행되었습니다.

범위 구분	내용
진단 유형	웹 애플리케이션 취약점 진단
진단 방식	수동 분석 기반 검증
진단 계정	*unauthenticated*
진단 환경	*staging*

[표 4] 수행 범위

4) 대상

번호	시스템명	대상 URL	계정 수준	비고
1	예시 서비스명	https://example.com	unauthenticated	sample target

[표 5] 웹 취약점 진단 대상

5) 일정

절차	일정	산출물	내용
정보 수집	2026-03-18	대상 정보 정리	대상 URL 및 진단 조건 확인
웹 취약점 진단	2026-03-19	취약점 재현 및 보고서 초안	수동 검증과 증빙 수집 수행

[표 6] 절차 및 일정

6) 수행 인력

소속	성명	역할	책임 범위	연락처
Example Security	홍길동	Analyst	수동 검증 및 결과 분석	analyst@example.com

[표 7] 수행 인력

7) 수행 장소

장소	주소	진단 IP	접속 방식	비고
Seoul	Seoul, Republic of Korea	-	local file based evidence	로컬 증빙 기준 샘플 케이스

[표 8] 수행 장소 및 IP 주소

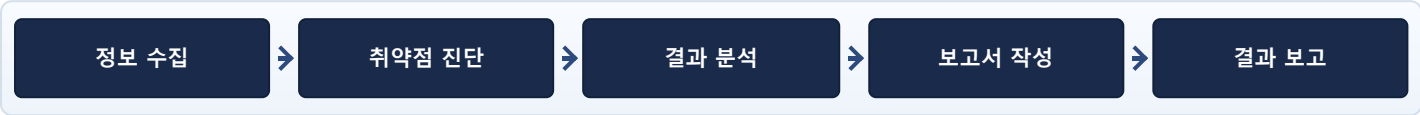
2. 웹 취약점 진단 개요

1) 점검 기준

본 웹 취약점 진단은 「주요정보통신기반시설 기술적 취약점 분석·평가 방법 상세가이드」와 OWASP Top 10 2021을 기본 기준으로 활용하였으며, 서비스 특성과 인증/인가 흐름을 고려하여 수동 검증 항목을 추가 반영하였습니다.

> 참고 기준: 주요정보통신기반시설 기술적 취약점 분석·평가 방법 상세가이드 / OWASP Top 10 2021 / 기관 내부 보안 요구사항

2) 진단 절차



[그림 1] 웹 취약점 진단 절차 흐름도

절차	수행 내용
정보 수집	대상 시스템 정보 수집, 인증 구조 파악, 테스트 계정/시나리오 및 진단 환경 구성
취약점 진단	체크리스트 기반 점검, 요청/응답 분석, 기능별 수동 검증 및 자동화 도구 보조 점검
결과 분석	발견 취약점의 재현 가능성, 영향 범위, 악용 조건 및 판정 근거 분석
보고서 작성	취약점별 상세 설명, 재현 절차, 증빙, 대응 방안, 재점검 기준 정리
결과 보고	발견 사항 공유, 조치 우선순위 협의, 재점검 범위 및 일정 조율

[표 9] 웹 취약점 진단 방법

3) 활용 도구

도구명	용도	비고

[표 10] 활용 도구

4) 위험도 기준

본 보고서의 최종 위험도는 취약점 파급도, 공격 난이도, 악용 선행조건, 영향 범위를 종합적으로 고려하여 판정합니다.

위험도	판정 기준	표기
상(High)	인증 우회, 권한 상승, 민감정보 탈취, 시스템 침해 등 직접적인 보안 사고로 이어질 수 있는 경우	상
중(Medium)	조건부 악용이 가능하거나 추가 조합이 필요한 경우로서 단기 내 조치가 필요한 경우	중
하(Low)	직접적 피해 가능성은 낮으나 보안 강화 및 오남용 예방 관점에서 개선이 필요한 경우	하
양호	취약점이 확인되지 않았으며 보안 요구사항을 충족하는 경우	양호

[표 11] 위험도 기준

5) 점검 체크리스트

아래 체크리스트는「주요정보통신기반시설 기술적 취약점 분석·평가 방법 상세가이드」기반 21개 항목입니다.

> ※ 본 표의 "기본 위험도(예시)"는 항목 성격에 따른 참조값이며, 최종 위험도는 상세 결과에서 실제 재현 결과와 영향 범위를 기준으로 판정합니다.

코드	항목명	점검 포인트	기본 위험도(예시)	결과
AU	자동화 공격	automated_attack	상	*취약*

[표 12] 웹 취약점 진단 체크리스트

3. 웹 취약점 진단 결과 요약

1) 전체 취약점 요약

구분	점검 항목 수	취약 건수	양호 건수	해당없음
예시 서비스명	*1*	*1*	*0*	*0*
합계	**1**	**1**	**0**	**0**

[표 13] 전체 취약점 요약

2) 위험도별 현황

위험도	건수	비율
상	1	100%
중	0	0%
하	0	0%
양호	0	0%
합계	**1**	**100%**

[표 14] 위험도별 취약점 현황

3) 대상별 결과 요약

번호	시스템명	관리번호	취약점명	위험도	상태
1	*예시 서비스명*	*VUL-001*	*로그인 실패 횟수 제한 미흡*	상	*미조치*

[표 15] 대상별 결과 요약

4) 총평

총 1건의 취약점이 발견되었으며, 대상은 1개 시스템입니다.

5) 조치 우선순위

아래 표는 최종 위험도, 악용 난이도, 영향 범위를 기준으로 조치 순서를 정리한 것입니다.

우선순위	관리번호	취약점명	위험도	조치 기한	담당자
1순위	*VUL-001*	*로그인 실패 횟수 제한 미흡*	상	-	-

[표 16] 조치 우선순위

4. 웹 취약점 진단 상세 결과

※ 아래 블록은 취약점 1건을 실무 제출 수준으로 정리하기 위한 기본 템플릿입니다. 동일 구조를 복사하여 취약점 건수만큼 반복 작성하십시오.

VUL-001 로그인 실패 횟수 제한 미흡 상

기본 정보

관리번호	VUL-001
대상 시스템	*예시 서비스명*
대상 URL	*https://example.com*
취약점명	*로그인 실패 횟수 제한 미흡*
점검 코드	*AU*
발생 경로	*https://example.com/login*

판정 및 조치 현황

진단 결과	*취약*
최종 위험도	상
발견일	*2026.03.19*
조치 기한	-
조치 상태	*미조치*
담당자	-
확인자	-

한 줄 요약

로그인 실패 횟수 제한 또는 CAPTCHA가 없어 반복 요청이 가능함

취약점 설명

로그인 기능에서 반복 인증 시도에 대한 제한이 없어 자동화 공격이 가능합니다.

Authentication endpoint accepted repeated failed login attempts without throttling.

No CAPTCHA or account lockout was observed after repeated failures.

발생 원인

로그인 실패 횟수 제한, CAPTCHA, 계정 잠금 정책이 부재합니다.

No CAPTCHA or account lockout was observed after repeated failures.

재현 절차

입력값/파라미터	-
요청 요약	*POST /login HTTP/1.1 / Host: example.com / Content-Type: application/x-www-form-urlencoded / Body: username=test@example.com&password=wrong-password*
응답 요약	*HTTP/1.1 200 OK / Content-Type: application/json / Body: {"message":"Invalid username or password","captchaRequired":false,"lockout":false}*
주요 증빙 ID	EVD-001, EVD-002, EVD-003, EVD-004

1. 로그인 페이지 접속

2. 반복 로그인 시도

3. 통제 부재 확인

재현 증빙

증빙 ID: EVD-003 *로그인 반복 요청 화면*

증빙 파일	*cases/web/case-001/input/evidence/screenshot-01.png*
요청/응답 요약	*로그인 반복 요청 화면*
관련 부록	Appendix C · EVD-003

[그림 4] VUL-001 재현 증빙 화면

관련 취약점: VUL-001 / 관련 증빙 ID: **EVD-003**

증빙 ID: EVD-004 *응답 결과 확인 화면*

증빙 파일	*cases/web/case-001/input/evidence/screenshot-02.png*
요청/응답 요약	*응답 결과 확인 화면*
관련 부록	Appendix C · EVD-004

[그림 5] VUL-001 재현 증빙 화면

관련 취약점: VUL-001 / 관련 증빙 ID: **EVD-004**

영향 범위

계정 존재 여부 식별 및 무차별 대입 공격 가능

VUL-001 로그인 실패 횟수 제한 미흡

상

상세 결과 계속 · VUL-001

위험도 및 판정 근거

인증 없이 접근 가능한 로그인 기능에서 반복 요청 제한이 없어 자동화 공격 성공 가능성이 높습니다.

- 공격 난이도: *낮음*
- 영향 자산: *인증 기능 및 사용자 계정*
- 선행 조건: *비인가 상태에서 로그인 페이지 접근 가능*

대응 방안

1. *rate limit 적용*
2. *CAPTCHA 또는 2차 검증 적용*
3. *계정 잠금 정책 검토*

참고 기준

- *OWASP Automated Threats to Web Applications*
- *내부 점검 코드 AU*

조치 후 재점검 결과

재점검일	
재점검 결과	*미수행*
확인 내용	*이번 샘플 범위에서는 재점검을 수행하지 않았습니다.*
비고	*로컬 샘플 케이스 / 반복 로그인 시도 시 별도의 CAPTCHA 또는 계정 잠금 정책이 동작하지 않음을 확인했습니다.*

5. 보호대책

※ 아래 보호대책은 상세 결과의 최종 위험도와 판정 근거를 바탕으로 단기·중기·장기 조치로 구분한 것입니다.

1) 단기 조치 (즉시 ~ 1개월 이내)

관리번호	취약점명	최종 위험도	조치 내용	담당 부서	완료 예정일	재점검 기준
VUL-001	*로그인 실패 횟수 제한 미흡*	상	*rate limit 적용 / CAPTCHA 또는 2차 검증 적용 / 계정 잠금 정책 검토*	-	-	*동일 재현 절차 및 회귀 테스트를 수행합니다.*
AGGREGATED	*보고서 단위 집계 조치*	하	*rate limit 적용 / CAPTCHA 또는 2차 검증 적용 / 계정 잠금 정책 검토*	-	-	*전체 조치 완료 후 다건 회귀 테스트를 수행합니다.*

[표 17] 단기 조치 목록

2) 중기 조치 (1개월 ~ 3개월 이내)

관리번호	취약점명	최종 위험도	조치 내용	담당 부서	완료 예정일	재점검 기준

[표 18] 중기 조치 목록

3) 장기 조치 (3개월 이상)

관리번호	취약점명	최종 위험도	조치 내용	담당 부서	완료 예정일	재점검 기준

[표 19] 장기 조치 목록

부록 A. 상세 점검 체크리스트

아래 체크리스트는 각 시스템별로 복사하여 사용하십시오.

코드	항목명	점검 방법 요약	결과	발견 URL	비고
CI	코드 인젝션	입력 파라미터에 인젝션 구문 삽입 후 실행 여부 확인	*[양호/취약]*	*[URL]*	
SI	SQL 인젝션	SQL 구문 삽입 후 DB 오류 또는 정보 노출 여부 확인	*[양호/취약]*		
DI	디렉터리 인덱싱	디렉터리 URL 직접 접근 시 목록 출력 여부 확인	*[양호/취약]*		
EP	에러 페이지 적용 미흡	의도적 오류 유발 후 상세 에러 메시지 노출 여부 확인	*[양호/취약]*		
IL	정보 누출	응답 헤더, 소스코드, 주석 내 민감 정보 노출 여부 확인	*[양호/취약]*		
XS	크로스사이트 스크립팅	입력 필드에 스크립트 삽입 후 실행 여부 확인	*[양호/취약]*		
CF	CSRF	CSRF 토큰 적용 여부 및 위조 요청 성공 여부 확인	*[양호/취약]*		
SF	SSRF	외부 URL 파라미터를 통한 내부 요청 여부 확인	*[양호/취약]*		
BF	약한 비밀번호 정책	단순 패스워드 설정 가능 여부 및 잠금 정책 확인	*[양호/취약]*		
IA	불충분한 인증 절차	인증 우회 가능 여부 확인	*[양호/취약]*		
IN	불충분한 권한 검증	권한 외 페이지/기능 접근 가능 여부 확인	*[양호/취약]*		
PR	취약한 비밀번호 복구 절차	비밀번호 찾기 기능의 보안 메커니즘 확인	*[양호/취약]*		
PV	프로세스 검증 누락	결제·인증 등 다단계 프로세스 우회 가능 여부 확인	*[양호/취약]*		
FU	악성 파일 업로드	웹셸 등 악성 파일 업로드 및 실행 가능 여부 확인	*[양호/취약]*		
FD	파일 다운로드	경로 조작을 통한 임의 파일 다운로드 가능 여부 확인	*[양호/취약]*		
IS	불충분한 세션 관리	세션 고정·예측·만료 미흡 여부 확인	*[양호/취약]*		
SN	데이터 평문 전송	HTTP 사용 여부 및 중요 데이터 평문 전송 여부 확인	*[양호/취약]*		
CC	쿠키 변조	Secure/HttpOnly 플래그 미설정 및 쿠키 변조 가능 여부	*[양호/취약]*		
AE	관리자 페이지 노출	/admin, /manager 등 관리자 URL 직접 접근 가능 여부	*[양호/취약]*		
AU	자동화 공격	로그인 실패 횟수 제한, CAPTCHA 적용 여부 확인	*[양호/취약]*		
WM	불필요한 Method 악용	OPTIONS, PUT, DELETE 등 허용 Method 확인	*[양호/취약]*		

부록 B. 점검 기준 참고표

본 진단에 적용된 점검 기준 및 참고 자료 목록입니다.

구분	기준/참고자료명	발행기관	버전/연도
가이드라인	주요정보통신기반시설 기술적 취약점 분석·평가 방법 상세가이드	*{{발행기관}}*	*{{연도/버전}}*
국제표준	OWASP Top 10 2021	OWASP Foundation	2021
[추가]	*{{기준명}}*	*{{발행기관}}*	*{{연도}}*

[표 20] 점검 기준 참고표

취약점 코드 참고표

※ 아래 위험도는 분류 참고용 예시이며, 최종 위험도는 상세 결과에서 실제 영향 범위와 재현 결과를 기준으로 판정합니다.

코드	항목명 (한)	항목명 (영)	기본 위험도(예시)
CI	코드 인젝션	Code Injection	상
SI	SQL 인젝션	SQL Injection	상
DI	디렉터리 인덱싱	Directory Indexing	상
EP	에러 페이지 적용 미흡	Improper Error Page	상
IL	정보 누출	Information Leakage	상
XS	크로스사이트 스크립팅	Cross-Site Scripting (XSS)	상
CF	크로스사이트 요청 위조	Cross-Site Request Forgery (CSRF)	상
SF	서버사이드 요청 위조	Server-Side Request Forgery (SSRF)	상
BF	약한 비밀번호 정책	Weak Password Policy	상
IA	불충분한 인증 절차	Insufficient Authentication	상
IN	불충분한 권한 검증	Insufficient Authorization	상
PR	취약한 비밀번호 복구 절차	Weak Password Recovery	상
PV	프로세스 검증 누락	Process Validation Failure	상
FU	악성 파일 업로드	Malicious File Upload	상
FD	파일 다운로드	File Download	상
IS	불충분한 세션 관리	Insufficient Session Management	상
SN	데이터 평문 전송	Sensitive Data Exposure	상
CC	쿠키 변조	Cookie Manipulation	상
AE	관리자 페이지 노출	Admin Page Exposure	상
AU	자동화 공격	Automated Attack	상
WM	불필요한 Method 악용	Unnecessary HTTP Method	상

[표 21] 취약점 코드 참고표

부록 C. 추가 증빙 자료

※ 본 섹션은 본문 상세 결과와 분리하여 관리해야 하는 추가 증빙 자료를 정리하는 영역입니다. 각 증빙은 증빙 ID, 관련 취약점 관리번호, 제목, 설명을 함께 기록하십시오.

증빙 ID: EVD-001

[관련 취약점: VUL-001]

제목	*재현 요청 전문*
관련 취약점	VUL-001
증빙 구분	*request*
본문 참조	4장 상세 결과 · EVD-001

[증빙 파일] cases/web/case-001/input/http/request.txt

[그림 02] Appendix C 추가 증빙 화면 (#1)

설명: *재현 요청 전문 파일 경로를 보존합니다. (cases/web/case-001/input/http/request.txt)*

증빙 ID: EVD-002

[관련 취약점: VUL-001]

제목	*재현 응답 전문*
관련 취약점	VUL-001
증빙 구분	*response*
본문 참조	4장 상세 결과 · EVD-002

[증빙 파일] cases/web/case-001/input/http/response.txt

[그림 03] Appendix C 추가 증빙 화면 (#2)

설명: *재현 응답 전문 파일 경로를 보존합니다. (cases/web/case-001/input/http/response.txt)*

증빙 ID: EVD-003

[관련 취약점: VUL-001]

제목	*로그인 반복 요청 화면*
관련 취약점	VUL-001
증빙 구분	*screenshot*
본문 참조	4장 상세 결과 · EVD-003

[그림 04] Appendix C 추가 증빙 화면 (#3)

설명: *본문 재현 단계와 연결되는 스크린샷 증빙입니다. (cases/web/case-001/input/evidence/screenshot-01.png)*

부록 C. 추가 증빙 자료

추가 증빙 자료 계속

증빙 ID: EVD-004

[관련 취약점: VUL-001]

제목	*응답 결과 확인 화면*
관련 취약점	VUL-001
증빙 구분	*screenshot*
본문 참조	4장 상세 결과 · EVD-004

[그림 05] Appendix C 추가 증빙 화면 (#4)

설명: *본문 재현 단계와 연결되는 스크린샷 증빙입니다. (cases/web/case-001/input/evidence/screenshot-02.png)*